
Plan de Tratamiento de Riesgos

Evaluación de Controles y Plan de Tratamiento de Riesgos

Empresa: D&D Servicio Integral de Limpieza

Preparado para	D&D Servicio Integral de Limpieza
Documento complementario	Assessment Inicial de Seguridad
Clasificación	Experiencia real — Versión pública anonimizada
Elaborado Por	Francisco Noya
Versión	1.0
Fecha	17 de Julio de 2026

Evaluación de Controles – D&D

ID	Riesgo	Control actual	Estado
C-01	Hackeo de correo	Contraseña	Parcial
C-02	Cuentas compartidas	Ninguno	No implementado
C-03	Pérdida de archivos	OneDrive	Parcial
C-04	Ransomware	Antivirus	Parcial
C-05	Falla de equipos	Ninguno	No implementado
C-06	Error humano	Actualizaciones automáticas	Parcial

Controles Recomendados (alineados con ISO 27001)

Control	Objetivo	ISO 27001
MFA en correos	Proteger cuentas	A.5 / A.8
Cuentas individuales	Trazabilidad	A.5.15
Política de contraseñas	Fortalecer accesos	A.5.17
Pruebas de restauración	Validar backups	A.8.13
Inventario de activos	Control de equipos	A.5.9
Procedimiento de incidentes	Responder rápido	A.5.24
Capacitación básica	Reducir errores	A.6.3

Plan de Tratamiento de Riesgos

Riesgo	Tratamiento	Prioridad
R-01 Hackeo de correo	Activar MFA	Muy Alta
R-02 Cuentas compartidas	Crear usuarios individuales	Muy Alta
R-03 Pérdida de planillas	Prueba mensual de restauración	Alta
R-04 Indisponibilidad de OneDrive	Copia adicional local	Alta
R-05 Falla de PC	Equipo de reemplazo	Alta
R-06 Ransomware	Backups + capacitación	Alta

Matriz Prioridad vs Esfuerzo

Control	Impacto	Esfuerzo	Acción
MFA	Muy Alto	Bajo	Implementar YA
Cuentas individuales	Muy Alto	Bajo	Implementar YA
Política de contraseñas	Alto	Bajo	Semana 1
Prueba de backup	Alto	Medio	Semana 2
Capacitación	Medio	Bajo	Mes 1
Equipo de reemplazo	Medio	Alto	Mes 2

Roadmap de 90 días

Primeros 15 días

Prioridad máxima

- Activar MFA
- Eliminar contraseñas compartidas
- Crear inventario definitivo
- Definir responsable de seguridad (vos)

30 días

Alta

- Política de contraseñas
- Prueba de restauración de OneDrive
- Procedimiento de incidentes
- Documentar accesos

60–90 días

Media

- Capacitación al personal
- Revisión de backups
- Simulación de incidente
- Evaluación de continuidad operativa

Conclusión de la Evaluación de Controles y Plan de Tratamiento de Riesgos

Controles prioritarios 2	MFA y cuentas individuales
Controles ISO alineados 7	A.5 / A.6 / A.8
Assessment completado 85%	Muy avanzado